Writeup de : JohnCena (0Skill team)

Date : 21 March 2025
Box : Trial by Fire

Plateforme	Hack The Box
CTF	Trial by Fire
Difficulté	Very Easy
Auteur	JohnCena (0Skill team)

Table des matières

1 Trial by Fire 3

1.1 Déroulement de la box 3

1.2 🔭 Périmètre 3

1.3 🔍 Enumération 3

1.4 🤯 Exploitation 4

Toute reproduction ou modification sans l'accord explicite de son auteur est interdite.

1 Trial by Fire

1.1 Déroulement de la box

1.2 🔭 Périmètre

Description

```
As you ascend the treacherous slopes of the Flame Peaks, the scorching heat and shifting
volcanic terrain test your endurance with every step. Rivers of molten lava carve fiery
paths through the mountains, illuminating the night with an eerie crimson glow. The air is
thick with ash, and the distant rumble of the earth warns of the danger that lies ahead.
At the heart of this infernal landscape, a colossal Fire Drake awaits—a guardian of flame
and fury, determined to judge those who dare trespass. With eyes like embers and scales
hardened by centuries of heat, the Fire Drake does not attack blindly. Instead, it weaves
illusions of fear, manifesting your deepest doubts and past failures. To reach the
Emberstone, the legendary artifact hidden beyond its lair, you must prove your resilience,
defying both the drake's scorching onslaught and the mental trials it conjures. Stand
firm, outwit its trickery, and strike with precision—only those with unyielding courage
and strategic mastery will endure the Trial by Fire and claim their place among the
legends of Eldoria.
```

Objective

```
STTI with python payload
```

Flag

```
HTB{Fl4m3_P34ks_Tr141_Burn5_Br1ght_6ae3a728c8e8a52804a68a7d3c733e43}
```

1.3 🔍 Enumération

Fuzzer :

```
/index.html
/flamedrake
```

Toute reproduction ou modification sans l'accord explicite de son auteur est interdite.

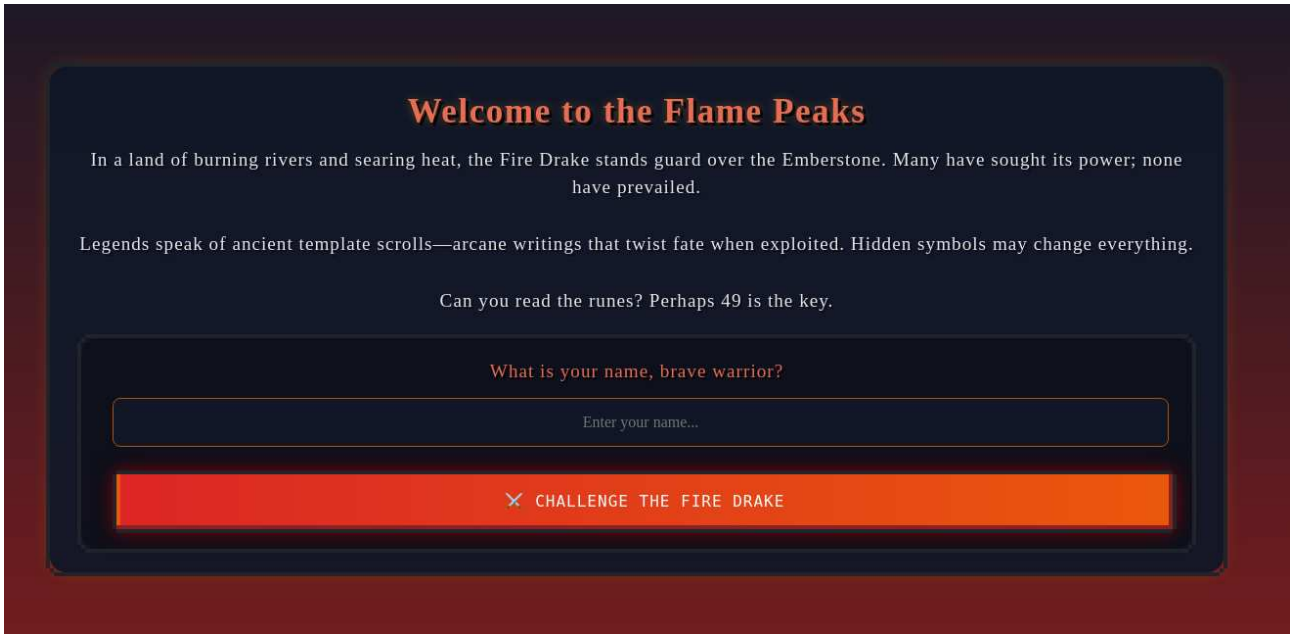
Writeup de : JohnCena (0Skill team)

Date : 21 March 2025
Box : Trial by Fire

Tech Stack :

```
Python
Flask
Nginx
```

Challenge :



1.4 🤯 Exploitation

It's a game where you have to fight a dragon.

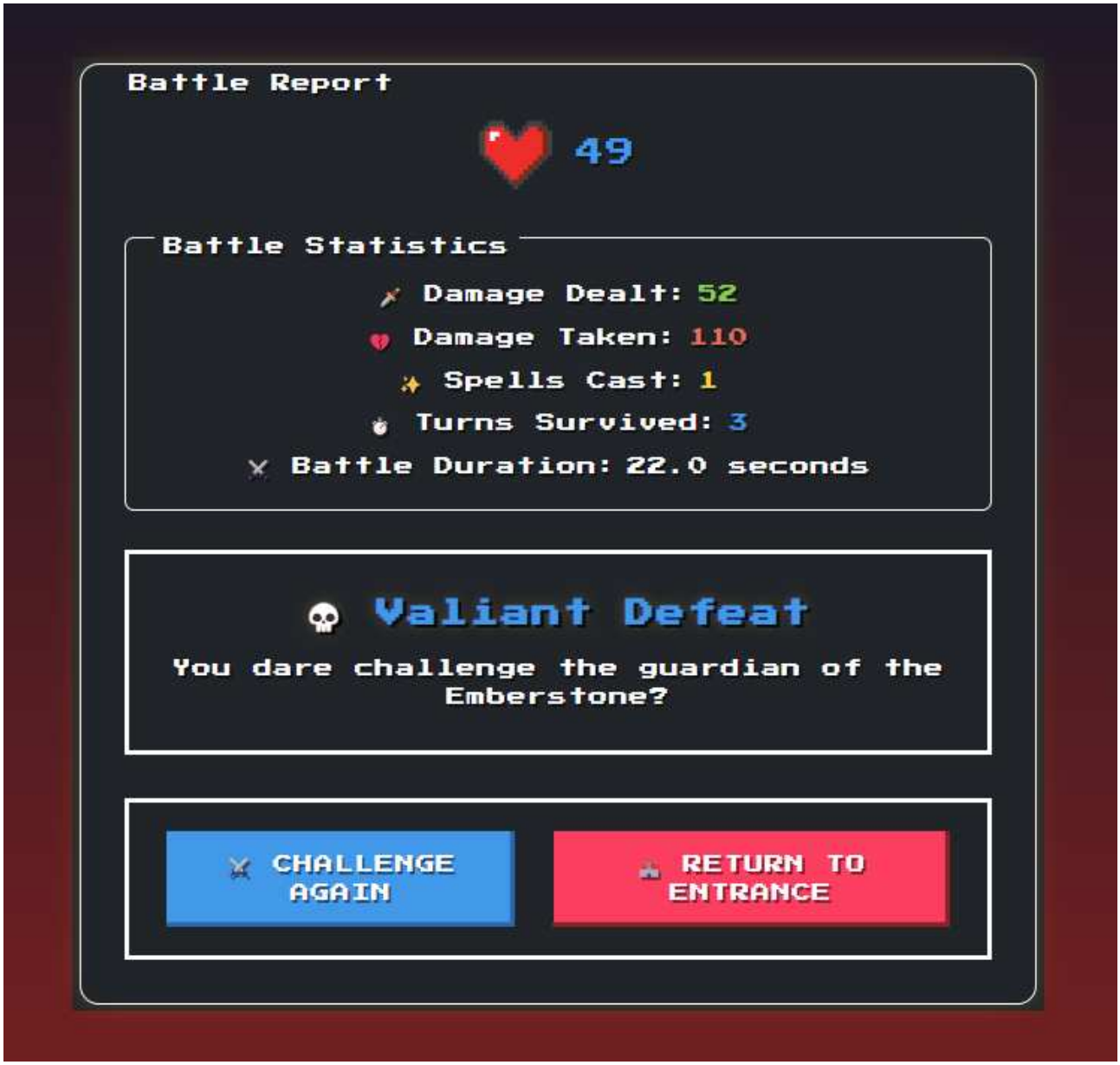
In the “name” field, I've placed a basic SSTI payload :

Result in game :

Toute reproduction ou modification sans l'accord explicite de son auteur est interdite.

Then, at the end of the fight, when we lose, the payload result is displayed (here = 49) :

Toute reproduction ou modification sans l'accord explicite de son auteur est interdite.



Now, with the files to be downloaded in this challenge, we realize that they're python, so we need a python SSTI payload.

After several Google searches, here's the payload that works :

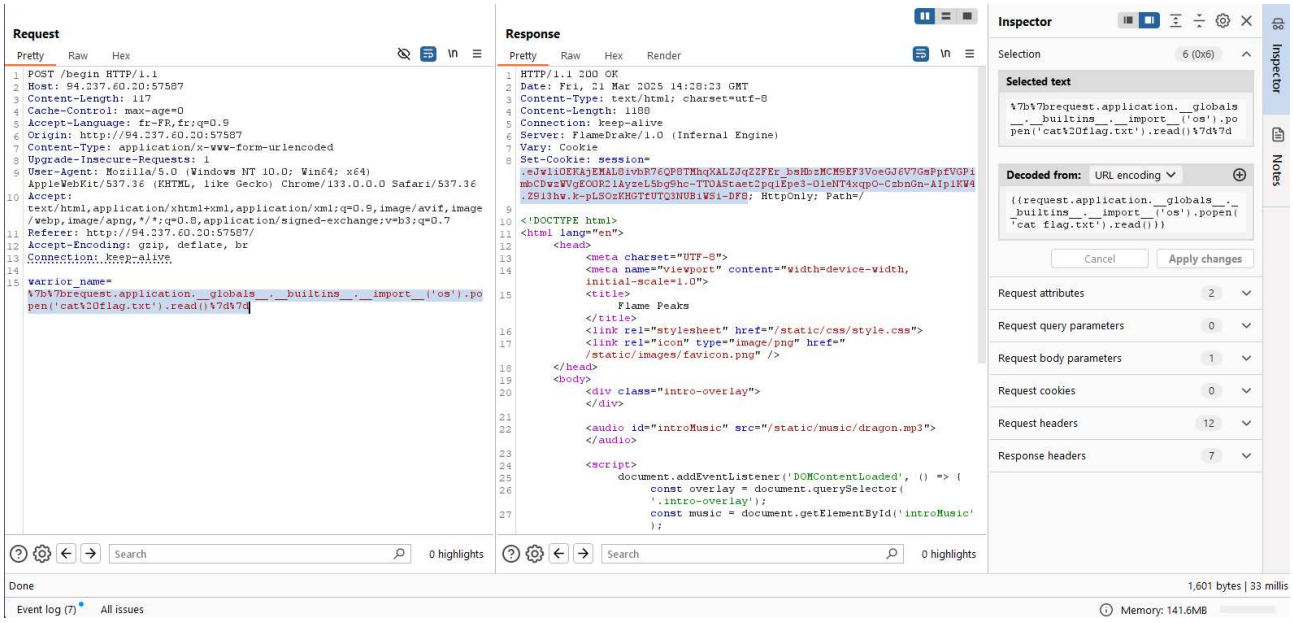
```
{{request.application.globals.builtins.import('os').popen('whoami').read()}}
```

So, we enter this payload in our name field and with `cat flag.txt` :

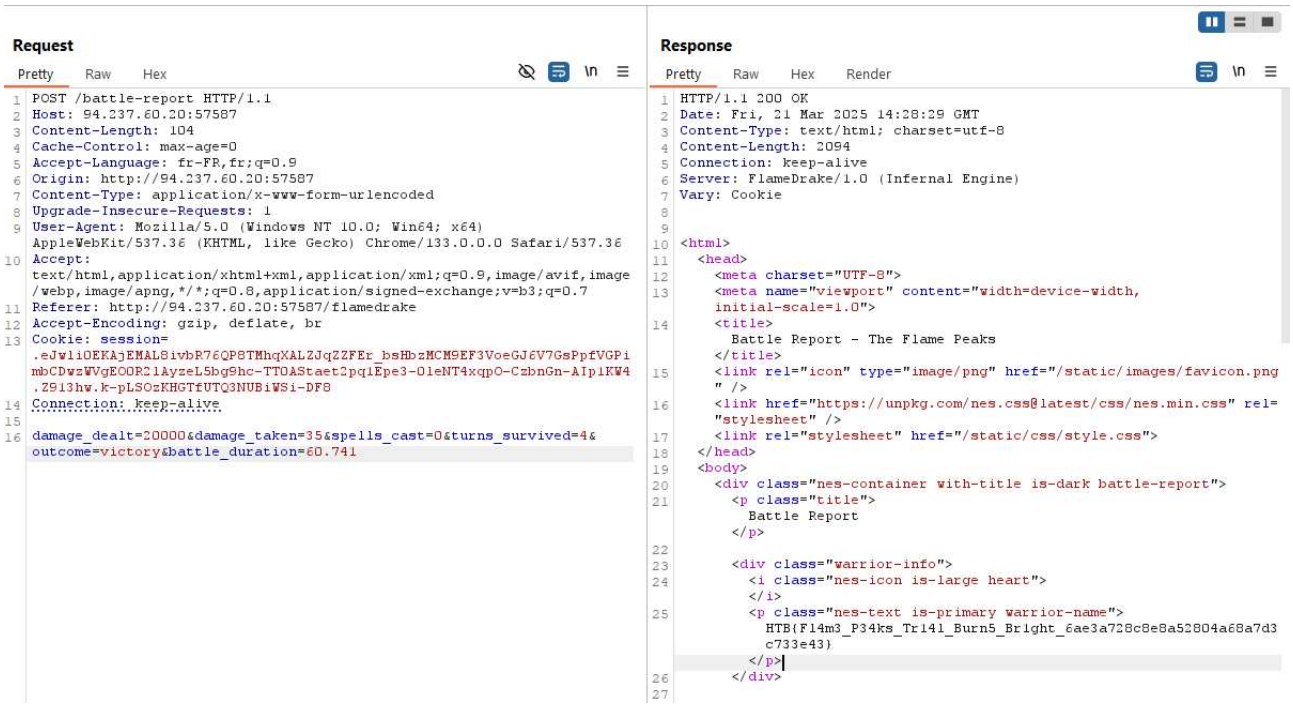
Toute reproduction ou modification sans l'accord explicite de son auteur est interdite.

Writeup de : JohnCena (0Skill team)

Date : 21 March 2025
Box : Trial by Fire



And finally, at the end of the battle within the game, the report is displayed to show the flag :



Toute reproduction ou modification sans l'accord explicite de son auteur est interdite.